Case 02 · מסמך עיצוב: Private Exposure Registry

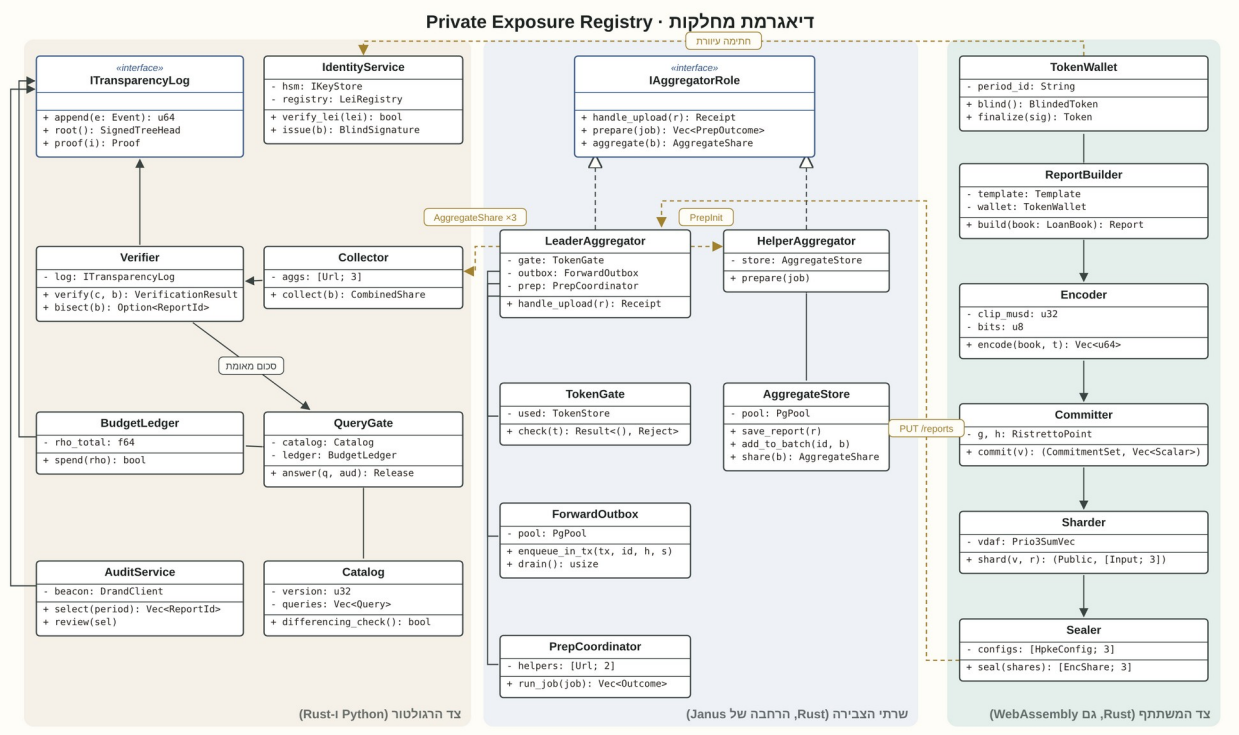
השלב שאחרי הארכיטקטורה. הארכיטקטורה קבעה אילו רכיבים יש ומה עובר ביניהם. העיצוב יורד רמה אחת: אילו מחלקות יש בתוך כל רכיב, באילו מצבים כל אובייקט חי, מי מדבר עם מי ובאיזה סדר, אילו תהליכונים רצים במקביל, ואיך נראות הטבלאות. המבנה זהה למסמך העיצוב של Case 01 ולמסמך של שרת הטריוויה.

עקרונות עיצוב

ארבעה עקרונות מכריעים כמעט כל החלטה במסמך הזה. כשיש ספק איך לבנות משהו, חוזרים אליהם.

- **אף אובייקט לא מחזיק גם זהות וגם תוכן:** המחלקה שיודעת מי המשתתף (IdentityService) לא רואה אף פעם דוח, והמחלקה שמקבלת דוחות (LeaderAggregator) לא יודעת מי שלח אותם. ההפרדה הזו היא לא נוהל, היא נאכפת במבנה: אין שדה, אין פרמטר ואין טבלה שמחברים את השניים.
- **היומן קודם:** כל שינוי מצב משמעותי נכתב קודם כאירוע ביומן השקיפות, ורק אחר כך מתעדכן המצב. אם המצב והיומן לא מסכימים, היומן צודק (Event Sourcing, כמו שנקבע בארכיטקטורה).
- **ממשק בכל גבול אמון:** בכל מקום שבו עוברים בין גופים שלא סומכים זה על זה, יש ממשק מופשט (IAggregatorRole, ITransparencyLog). כך אפשר להחליף מימוש, לבדוק עם מימוש מזויף, ולהוסיף צד שלישי בלי לגעת בשאר.
- **כשל סגור:** סכום שלא אומת לא נגיש לשאילתה. אין מצב "כמעט מאומת". כל ענף בכל מכונת מצבים שלא מסתיים באימות מסתיים בהסגר או בדחייה.

דיאגרמת מחלקות



הדיאגרמה מחולקת לשלושה אזורים, כמו שלושת סוגי הגופים בארכיטקטורה: הצד של המשתתף (ספריית לקוח שהמוסד המדווח מריץ אצלו), שרתי הצבירה (שלושה עותקים, אחד אצל כל רשות), והרגולטור (השכבה שמזהה, מאמתת, עונה לשאילתות ומבקרת).

החצים המקווקווים המסומנים הם הודעות רשת ולא קריאות לפונקציה: הם חוצים גבול אמון, ולכן כל אחד מהם מוצפן וחתום.

תפקיד כל מחלקה

מחלקה	אזור	תפקיד	מה היא לא עושה
TokenWallet	משתתף	מחזיקה אסימונים עיוורים שהונפקו מראש, אחד לכל תקופת דיווח	לא יודעת לאיזה דוח ישויך כל אסימון עד רגע השליחה
ReportBuilder	משתתף	אוספת את 33 התאים מהמערכות הפנימיות של המוסד ובודקת טווחים	לא מצפינה ולא שולחת
Encoder	משתתף	ממירה את התאים למספרים שלמים בשדה סופי לפי התבנית, עבור Prio3SumVec ו- Prio3Histogram	לא יודעת על השרתים
Committer	משתתף	יוצרת התחייבות Pedersen על Ristretto255 לכל תא, ושומרת את האקראיות	לא משתפת את האקראיות עם אף אחד
Sharder	משתתף	מפצלת לשלושה חלקים אקראיים שסכומם הוא הנתון, ומצרפת הוכחת טווח	לא שולחת
Sealer	משתתף	מצפינה כל חלק במפתח HPKE של השרת שלו (RFC 9180)	לא רואה את התוכן אחרי ההצפנה
IAggregatorRole	צבירה	ממשק משותף למוביל ולעוזרים: קבלת חלק, הכנה, צבירה	
LeaderAggregator	צבירה	מקבל את הדוח, מעביר חלקים לעוזרים, מנהל את עבודות הצבירה	לא מחזיק מפתח פענוח של העוזרים
HelperAggregator	צבירה	מפענח את החלק שלו, בודק את ההוכחה, צובר	לא מקבל דוחות ישירות ממשתתפים
TokenGate	צבירה	מאמת אסימון עיוור ומסמן אותו כמשומש	לא יודע מי קיבל את האסימון
ForwardOutbox	צבירה	שומר העברות לעוזרים באותה טרנזקציה של הקבלה, ושולח שוב עד הצלחה	לא מחליט אם דוח תקין
PrepCoordinator	צבירה	מריץ את שלב ההכנה של VDAF מול העוזרים ומחליט על כל דוח: מתקבל או נדחה	
AggregateStore	צבירה	מחזיק את הסכום החלקי של כל אצווה בשרת הזה	לא יכול לפענח סכום של שרת אחר
IdentityService	רגולטור	מאמת LEI מול GLEIF ומנפיק אסימונים עיוורים לפי Privacy Pass	לא רואה דוחות
Verifier	רגולטור	משווה את הסכום שהתקבל לסכום ההתחייבויות; אם לא תואם, מחפש בחציה	
Collector	רגולטור	אוסף את שלושת הסכומים החלקיים ומחבר אותם	לא רואה דוח בודד
BudgetLedger	רגולטור	מנהל את תקציב הפרטיות (zCDP) של כל אצווה	
QueryGate	רגולטור	מקבל שאילתה מהקטלוג, בודק סף K_MIN והפרשים,	לא עונה על שאילתה שאינה בקטלוג

מחלקה	אזור	תפקיד	מה היא לא עושה
		מוסיף רעש Discrete Gaussian	
AuditService	רגולטור	מגריל משתתפים לביקורת לפי drand ומבקש מהם לפתוח התחייבות	לא מגריל לפי שיקול דעת
Catalog	רגולטור	רשימה סגורה של שאילתות מותרות, מאושרת בשלושה מפתחות	
ITransparencyLog	משותף	ממשק ליומן Trillian: הוספת אירוע, הוכחת הכללה, הוכחת עקביות	

פרוטוקול ההודעות

כמו בשרת הטריוויה, כל הודעה מוגדרת מראש: מי שולח, מה בתוכה, ומה התשובות האפשריות. הפרוטוקול נשען על DAP (draft-ietf-ppm-dap-19), ולכן רוב ההודעות הן הודעות DAP קיימות, עם שתי הרחבות: אסימון עיוור והתחייבויות.

משתתף אל המוביל

```
PUT /tasks/{task_id}/reports
Content-Type: application/dap-report
Body:
  report_metadata { report_id: 16 bytes, time: uint64 }
  public_share    { commitments: 33 × 32 bytes }      הרחבה
  token           { blind_token: Privacy Pass }       הרחבה
  leader_share    HPKE ciphertext
  helper_shares   [ HPKE ciphertext × 2 ]
```

תשובה	משמעות	מה המשתתף עושה
Created + Receipt 201	הדוח נקלט ונכתב ביומן. ה-Receipt כולל הוכחת הכללה	שומר את ה-Receipt כראיה לרגולטור
invalid_token 400	האסימון לא תקף או לא מהתקופה הזו	מבקש אסימון חדש ב-IdentityService
duplicate 409	האסימון כבר שומש	לא שולח שוב: הדוח הקודם נקלט
period_closed 410	התקופה נסגרה	פונה לרגולטור בערוץ הרגיל

מוביל אל עוזר

```
PUT /tasks/{task_id}/aggregation_jobs/{job_id}
Body: AggregationJobInitReq { prep_inits: [ PrepInit{ report_share,
leader_prep_share } ] }
Resp: AggregationJobResp   { prep_resps: [ PrepResp{ report_id, continue |
reject(reason) } ] }
```

עם שלושה שרתים, המוביל מריץ את ההכנה מול שני העוזרים, ודוח מתקבל רק אם שלושתם הסכימו שההוכחה תקינה.

הרגולטור אל השרתים

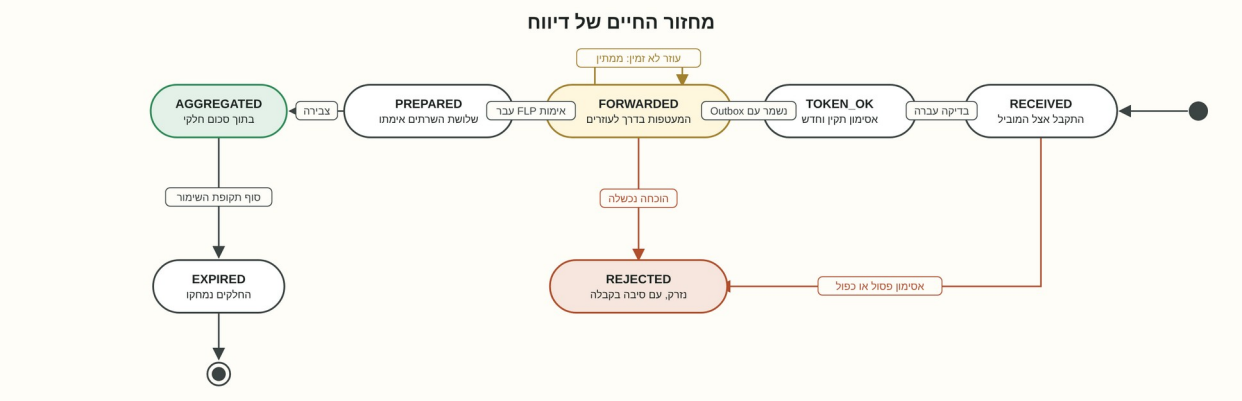
```
POST /tasks/{task_id}/collection_jobs/{collect_id}
Body: { batch_id, aggregation_param }
Resp: Collection { report_count, interval, encrypted_agg_shares: [ × 3 ] }
```

אירועי היומן

אירוע	נכתב על ידי	מתי	מה בתוכו
ReportReceived	LeaderAggregator	קבלת דוח	report_id, גיבוב ההתחייבויות, זמן. לא מי שלח
ReportRejected	PrepCoordinator	הוכחה נכשלה	report_id, סיבה
BatchClosed	LeaderAggregator	סוף תקופה	batch_id, מספר דוחות
BatchVerified	Verifier	הסכום תואם להתחייבויות	batch_id, גיבוב הסכום
BatchVerificationFailed	Verifier	אי התאמה	batch_id, הדוחות שבהסגר
CatalogApproved	Catalog	גרסה חדשה של הקטלוג	גרסה, שלוש חתימות
QueryAnswered	QueryGate	תשובה לשאילתה	query_id, גרסת קטלוג, תוצאה עם רעש
BudgetSpent	BudgetLedger	אחרי כל תשובה	batch_id, ρ שנוצל, יתרה
AuditSelected	AuditService	הגרלה	סבב drand, המשתתפים שנבחרו

מכונות מצבים

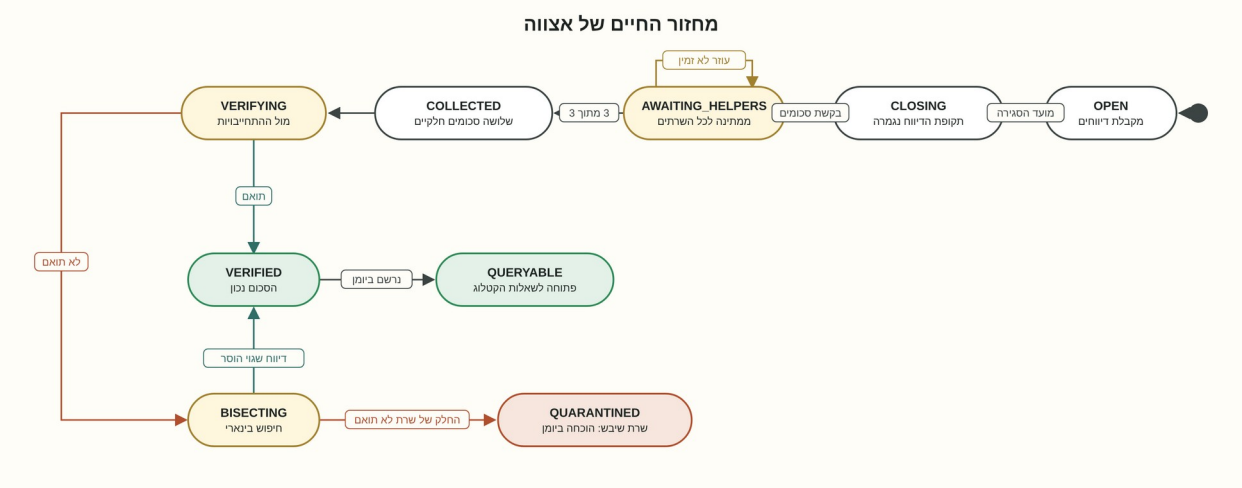
מחזור החיים של דוח



הדוח הוא האובייקט המרכזי במערכת, וכל מצב שלו נשמר בטבלת reports אצל המוביל. כמה דברים שכדאי לשים לב אליהם:

- הבדיקה הראשונה היא האסימון, לפני כל פענוח. כך התקפת הצפה עולה לתוקף אסימון לכל דוח, ולשרת כמעט כלום.
- **הלולאה העצמית ב-FORWARDED היא ה-Outbox:** אם עוזר לא זמין, הדוח לא נדחה ולא הולך לאיבוד. הוא מחכה, וההעברה חוזרת עד הצלחה.
- REJECTED הוא מצב סופי, ונכתב ביומן עם סיבה. דוח שנדחה לא נכנס לשום סכום.
- **EXPIRED:** אחרי שהאצווה אומתה ונשמרה, החלקים הבודדים נמחקים. אין סיבה להחזיק אותם, וכל יום שהם קיימים הוא סיכון.

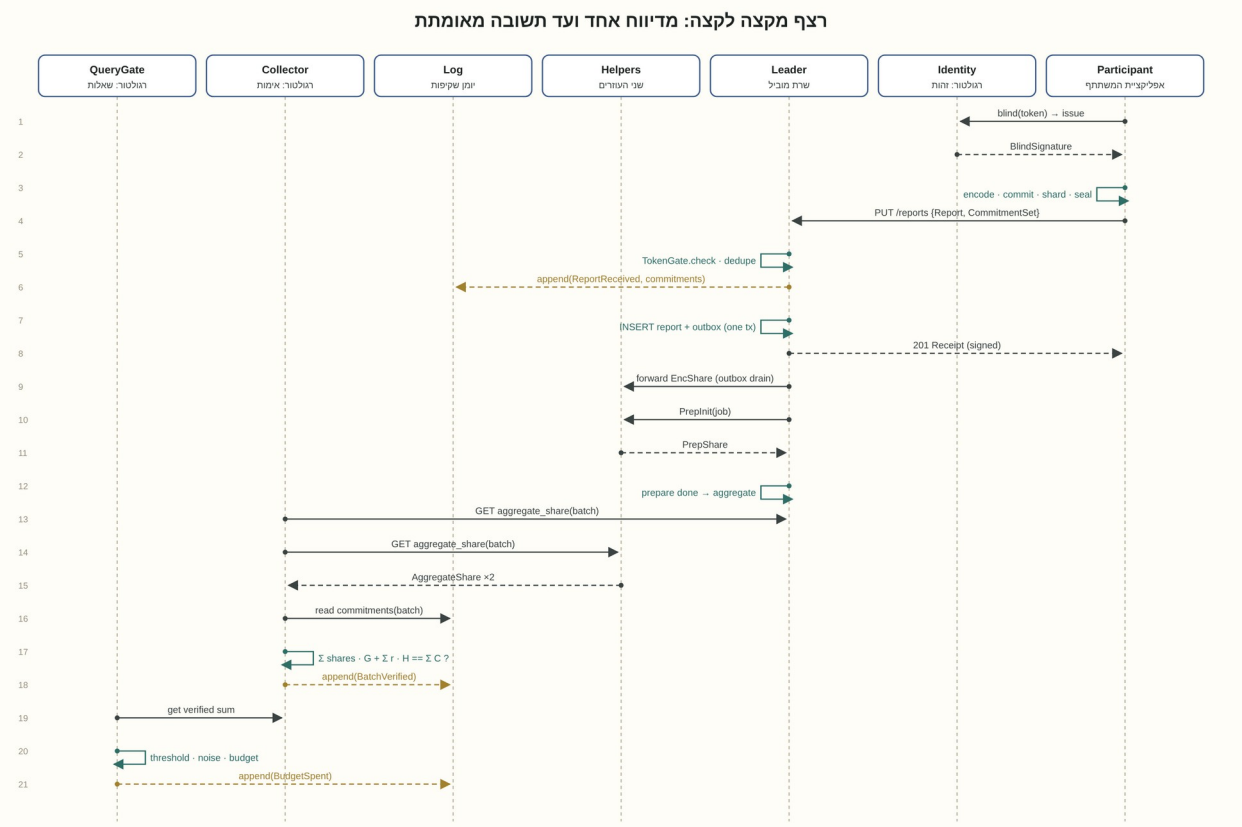
מחזור החיים של אצווה



האצווה היא האובייקט שהרגולטור רואה. היא נפתחת בתחילת תקופת דיווח ומגיעה ל-QUERYABLE רק אחרי אימות מלא.

- **VERIFYING:** Verifier מחשב את מכפלת כל ההתחייבויות ובודק שהיא מתחייבת לסכום שהתקבל. זו הבדיקה שמבטיחה ששרת לא הוסיף או השמיט דוח.
- **BISECTING:** אם הבדיקה נכשלה, האצווה מחולקת לשניים ונבדקת כל מחצית, עד שנמצאים הדוחות הבעייתיים. עם 500 משתתפים זה לכל היותר 9 סבבים.
- **QUARANTINED:** אם החיפוש לא מוצא מקור ברור, האצווה כולה בהסגר, והאירוע ביומן מודיע לכל שלוש הרשויות. זה הכשל הסגור מהעקרונות.

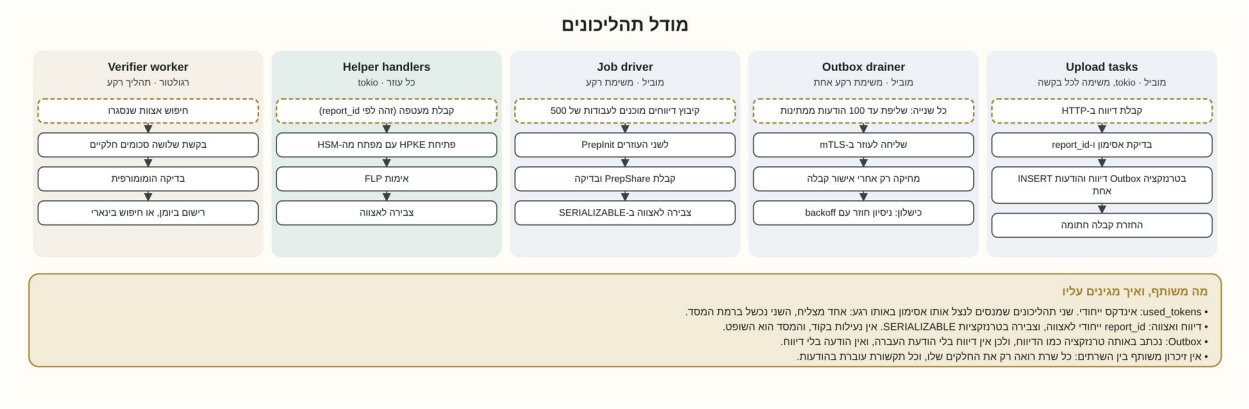
דיאגרמת רצף



הרצף מראה תקופת דיווח אחת מקצה לקצה: מהנפקת האסימון ועד שהתקציב נרשם. שלוש נקודות חשובות:

- שלבים 1 עד 3 קורים זמן רב לפני הדיווח. ההפרדה בזמן בין הנפקת האסימון לשימוש בו היא חלק מההגנה: גם אם IdentityService ו-TokenGate ישתפו פעולה, הם לא יכולים לחבר אסימון לדוח לפי התזמון.
- ReportReceived נכתב ביומן לפני שהמשתתף מקבל 201. אם הכתיבה ליומן נכשלה, המשתתף מקבל שגיאה ושולח שוב.
- רעש מתווסף רק בשלב השאילתה, לא בצבירה. הסכום המאומת נשאר מדויק, ורק מה שיוצא החוצה מורעש. כך אפשר לאמת, ואחר כך להגן.

מודל תהליכונים



כל שרת צבירה הוא תהליך Rust (Janus) עם runtime של tokio. המשמעות: יש מעט תהליכוני מערכת, ועליהם רצות אלפי משימות אסינכרוניות.

תהליכון או משימה	כמה	מה עושה	איך מסתנכרן
Upload tasks	אחת לכל בקשה	אימות אסימון, שמירת דוח, כתיבה ל-Outbox	טרנזקציה אחת ב-PostgreSQL
Outbox drainer	אחת לכל שרת	שולפת העברות ממתינות ושולחת לעוזרים	SELECT ... FOR UPDATE SKIP LOCKED
Job driver	מאגר קבוע	יוצר עבודות צבירה ומריץ את ההכנה	lease על השורה בטבלה
Helper handlers	אחת לכל בקשה	הכנה וצבירה אצל העוזר	טרנזקציה לכל עבודה
Verifier worker	אחת אצל הרגולטור	אימות אצוות שנסגרו	תור אירועים מהיומן

ארבעה כללים שמונעים התנגשויות

- **used_tokens עם אינדקס ייחודי:** שתי בקשות עם אותו אסימון שמגיעות באותה מילישנייה. אחת נכנסת, השנייה נכשלת על האינדקס ומקבלת 409. אין צורך בנעילה בקוד.
- **SERIALIZABLE בעדכון הסכום החלקי:** שתי עבודות שמוסיפות לאותה אצווה לא ידרסו זו את זו.
- **ה-Outbox באותה טרנזקציה:** הדוח וההעברה לעוזר נשמרים יחד או לא נשמרים בכלל. אין מצב שבו דוח נקלט ולא יגיע לעוזרים.
- **אין זיכרון משותף בין שרתים:** שלושת השרתים מדברים רק בהודעות. זו לא רק החלטת ביצועים, זו דרישת פרטיות.

עיצוב טבלאות



שני מסדי נתונים נפרדים לגמרי, ואין מפתח זר ביניהם. זה העיקרון הראשון בעיצוב, מתורגם לטבלאות: אין שום טבלה אצל הרגולטור שיש בה report_id, ואין שום טבלה אצל השרתים שיש בה LEI.

אצל כל שרת צבירה

טבלה	מה נשמר	הערה
tasks	הגדרת המשימה: VDAF, מפתחות HPKE, אורך תקופה	נטען פעם אחת בהגדרה
reports	דוח לפי report_id: החלק המוצפן, מצב, התחייבויות	נמחק במעבר ל-EXPIRED
used_tokens	גיבוב של כל אסימון שנוצל	אינדקס ייחודי. לא נמחק עד סוף התקופה
aggregate_shares	הסכום החלקי לכל אצווה ומספר הדוחות	מה שהרגולטור אוסף
pending_forwards	Outbox-ה: העברות שעוד לא אושרו	נמחקת שורה רק אחרי 200 מהעוזר

אצל הרגולטור

טבלה	מה נשמר	הערה
participants	LEI, רשות מפקחת, סטטוס	אין כאן שום נתון מדוח
token_issuance	כמה אסימונים הונפקו לכל משתתף בכל תקופה	לא האסימונים עצמם: הם עיוורים
catalog_versions	גרסאות הקטלוג, שלוש חתימות	רק גרסה חתומה פעילה
batches	מצב האצווה, הסכום המאומת	מגיעה ל-QUERYABLE רק אחרי אימות
budget_ledger	ρ שנוצל לכל אצווה	רק הוספה, אף פעם לא עדכון
releases	תשובות ששוחררו, עם הרעש	השאילתה הבאה בודקת הפרשים מול הטבלה הזו
audit_selections	סבב drand והמשתתפים שנבחרו	ניתן לשחזור על ידי כל אחד

סדר מימוש לפי גרסאות

כל גרסה עומדת בפני עצמה ונבדקת לפני שממשיכים. הסדר נקבע לפי אותו כלל של Case 01: קודם הליבה שאם היא לא עובדת אין טעם בשאר, אחר כך מה שמגן עליה, ובסוף מה שמשתמש בה.

גרסה	מה נבנה	מבחן היציאה
V0.1	ליבה של שני שרתים על Janus ו-libprio, דוח אחד וסכום אחד	500 דוחות מדומים, הסכום זהה לסכום הישיר
V0.2	שלושה שרתים, Outbox, הצפנת HPKE	עוזר שמכבים באמצע: אף דוח לא הולך לאיבוד
V0.3	התחייבויות, Verifier וחיפוש בחציה	שרת שמשמיט דוח בכוונה: נתפס, והדוח נמצא
V0.4	זיהוי LEI, אסימונים עיוורים, TokenGate	אותו אסימון פעמיים: 409. אסימון מזויף: 400
V0.5	יומן שקיפות Trillian	כל אירוע עם הוכחת הכללה, ועקביות בין שתי נקודות זמן
V0.6	קטלוג, QueryGate, רעש ותקציב	שתי שאילתות שההפרש ביניהן חושף משתתף: השנייה נחסמת
V1.0	דוחות לרגולטור, ביקורת מדגמית, ייצוא SDMX	תקופת דיווח מלאה, מקצה לקצה, עם שלוש רשויות

מה המסמך הזה סוגר

אחרי מסמך העיצוב, כל מחלקה יודעת מה היא עושה ומה היא לא עושה, כל אובייקט יודע לאן הוא יכול לעבור, וכל טבלה יודעת מה מותר לשמור בה. ההבטחה המרכזית של ה-Registry, לחבר בלי לראות, מתורגמת כאן לשורות קונקרטיות: אין שדה שמחבר זהות לתוכן, ואין מעבר מצב שמוביל לסכום לא מאומת.